Cloud Security Assessment

Client: Example Logistics Ltd.

Prepared by: Harbor & Pine Advisory, Security Practice

Date: 1 October 2026

Executive summary

We reviewed the production cloud environment and found 6 issues: 1 critical, 2 high, 2 medium and 1 low. The critical issue (a public storage bucket with shipment exports) should be fixed this week. The others can be planned over the next quarter.

Severity	Findings
Critical	1
High	2
Medium	2
Low	1

Scope

Production AWS account, customer-facing web application and CI/CD pipeline. Testing ran from 15 to 26 September 2026.

Findings overview

ID	Finding	Severity	Area
F-01	Storage bucket with shipment exports is publicly readable	Critical	Storage
F-02	Root account has no MFA	High	Identity
F-03	Long-lived deploy keys in the CI pipeline	High	CI/CD
F-04	Database snapshots are not encrypted	Medium	Data
F-05	Web application sends no security headers	Medium	Application
F-06	Audit log retention is 30 days	Low	Logging

Detailed findings

F-01: Storage bucket with shipment exports is publicly readable

Severity: Critical · **Area:** Storage

The bucket that stores nightly shipment exports allows anonymous read access. The files contain customer names and delivery addresses.

Recommendation: Block public access on the bucket and the account, rotate the export links already shared, and review access logs for the last 90 days.

F-02: Root account has no MFA

Severity: High · **Area:** Identity

The AWS root user can sign in with a password only. It was last used 41 days ago.

Recommendation: Enable hardware MFA on the root user, store the device securely and alert on any root sign-in.

F-03: Long-lived deploy keys in the CI pipeline

Severity: High · **Area:** CI/CD

The pipeline uses an IAM user access key created 14 months ago with administrator permissions.

Recommendation: Replace the key with short-lived OIDC credentials and a role limited to the deploy actions.

F-04: Database snapshots are not encrypted

Severity: Medium · **Area:** Data

Manual snapshots of the orders database are stored without encryption at rest.

Recommendation: Copy the snapshots with encryption enabled, delete the unencrypted copies and enforce encryption by policy.

F-05: Web application sends no security headers

Severity: Medium · **Area:** Application

Responses lack Content-Security-Policy, Strict-Transport-Security and X-Content-Type-Options headers.

Recommendation: Add the headers at the load balancer or CDN and start with a report-only Content-Security-Policy.

F-06: Audit log retention is 30 days

Severity: Low · **Area:** Logging

Audit logs are kept for 30 days, shorter than the 1-year retention in the client's own policy.

Recommendation: Move audit logs to a dedicated archive bucket with a 1-year lifecycle rule.